

Vereinbarung über die Auftragsverarbeitung (AVV) für Berufsgeheimnisträger und Projekte mit erhöhtem Schutzbedarf

gemäß Art. 28 Abs. 3 Datenschutz-Grundverordnung (DSGVO)

zwischen

[Name/Firma des Auftraggebers]

[Anschrift]

1 nachfolgend Verantwortlicher oder Auftraggeber -

und

Laurenz Gilbert / Gilbert Webdesign

Argentinische Allee 93

14163 Berlin

1 nachfolgend Auftragsverarbeiter oder Auftragnehmer -

1. Gegenstand und Dauer

- 1 Gegenstand dieser Vereinbarung ist die Verarbeitung personenbezogener Daten durch den Auftragnehmer im Auftrag des Auftraggebers im Zusammenhang mit der Entwicklung, technischen Betreuung, Wartung, Pflege, Fehleranalyse, Berechtigungsverwaltung, Migration und administrativen Unterstützung in Bezug auf die Website und die zugehörigen Systeme des Auftraggebers.
- 2 Die Verarbeitung erfolgt ausschließlich zur Erfüllung des Hauptvertrages über Webdesign-, Wartungs-, Support- und Entwicklungsleistungen.
- 3 Diese Vereinbarung gilt ab Unterzeichnung und läuft für die Dauer des Hauptvertrages. Sie endet automatisch mit Beendigung des Hauptvertrages, soweit keine gesetzlichen Aufbewahrungspflichten oder einzelne Bestimmungen darüber hinaus fortgelten.

2. Art, Zweck und Umfang der Verarbeitung

- 1 Art und Zweck der Verarbeitung ergeben sich aus dem Hauptvertrag sowie dieser Vereinbarung. Der Auftragnehmer kann insbesondere mit folgenden Tätigkeiten befasst sein:
 - Zugriff auf Hosting-, DNS-, CDN-, Worker-, Pages-, CMS- oder vergleichbare Web-Infrastrukturen des Auftraggebers
 - Zugriff auf Quellcode-Repositories, Deployment- und Build-Systeme
 - technische Fehleranalyse, Wartung, Updates, Konfigurationsänderungen und Support
 - Einrichtung und Pflege von Formularen, Integrationen und Content-Systemen

- Wiederherstellung, Migration oder Übertragung technischer Umgebungen
- 2 Die Verarbeitung erfolgt nur insoweit, wie dies zur Erbringung der beauftragten Leistungen erforderlich ist.
- 3 Eine eigenständige Nutzung der Daten für eigene Zwecke des Auftragnehmers ist ausgeschlossen.
- 4 Der Auftraggeber bleibt für die rechtliche Zulässigkeit der Verarbeitung, die datenschutzrechtliche Bewertung des konkreten Projekt- und Systemeinsatzes sowie die Entscheidung verantwortlich, welche personenbezogenen Daten oder geheimnisschutzrelevanten Inhalte über welche Systeme, Formulare, Integrationen oder sonstigen Dienste verarbeitet werden sollen. Der Auftragnehmer erbringt insoweit keine Rechtsberatung.

3. Art der Daten und Kategorien betroffener Personen

- 1 Von der Verarbeitung können insbesondere folgende Datenarten betroffen sein:
 - Stammdaten und Kontaktdaten
 - Kommunikationsdaten
 - Inhaltsdaten aus Formularen, E-Mails oder sonstigen Website-Eingaben
 - Nutzungs-, Protokoll- und Metadaten
 - IP-Adressen und Logdaten
 - Administrations- und Accountdaten
 - besondere Kategorien personenbezogener Daten im Sinne des Art. 9 DSGVO, soweit solche Daten im konkreten Projekt verarbeitet werden
 - sonstige vertrauliche Informationen und Geheimnisse, die einem besonderen gesetzlichen, berufsrechtlichen oder vertraglichen Geheimnisschutz unterliegen können
- 2 Betroffene Personen können insbesondere sein:
 - Websitebesucher
 - Interessenten, Kunden, Mandanten, Patienten, Klienten oder sonstige Anfragende des Auftraggebers
 - Beschäftigte oder sonstige Nutzerkonten des Auftraggebers

4. Weisungsrecht des Auftraggebers

- 1 Der Auftragnehmer verarbeitet personenbezogene Daten ausschließlich auf dokumentierte Weisung des Auftraggebers, sofern er nicht durch das Recht der Union oder der Mitgliedstaaten zur Verarbeitung verpflichtet ist.

- 2 Weisungen sind grundsätzlich in Textform zu erteilen. Mündliche Weisungen sind unverzüglich in Textform zu bestätigen.
- 3 Der Auftragnehmer informiert den Auftraggeber unverzüglich, wenn er der Auffassung ist, dass eine Weisung gegen datenschutzrechtliche Vorschriften verstößt.

5. Pflichten des Auftragnehmers

- 1 Der Auftragnehmer gewährleistet, dass Personen, die unter seiner Verantwortung personenbezogene Daten oder sonstige geheimnisschutzrelevante Informationen verarbeiten, zur Vertraulichkeit verpflichtet sind oder einer angemessenen gesetzlichen Verschwiegenheitspflicht unterliegen.
- 2 Der Auftragnehmer trifft alle nach Art. 32 DSGVO erforderlichen technischen und organisatorischen Maßnahmen. Die zum Zeitpunkt des Vertragsschlusses vereinbarten Maßnahmen ergeben sich aus Anlage 2.
- 3 Der Auftragnehmer unterstützt den Auftraggeber unter Berücksichtigung der Art der Verarbeitung und der ihm zur Verfügung stehenden Informationen bei der Erfüllung der Pflichten des Auftraggebers nach Art. 32 bis 36 DSGVO, insbesondere in Bezug auf:
 - Sicherheit der Verarbeitung
 - Meldung von Verletzungen des Schutzes personenbezogener Daten
 - Benachrichtigung betroffener Personen
 - Datenschutz-Folgenabschätzungen
 - vorherige Konsultationen mit Aufsichtsbehörden
- 4 Die Unterstützung nach dieser Vereinbarung erfolgt nur im erforderlichen und dem Auftragnehmer zumutbaren Umfang sowie auf Grundlage der dem Auftragnehmer tatsächlich verfügbaren Informationen und Zugriffsmöglichkeiten.
- 5 Soweit Unterstützungsleistungen nach dieser Vereinbarung nicht bereits ausdrücklich vom Hauptvertrag umfasst sind, können sie vom Auftragnehmer gesondert nach Aufwand zu den vereinbarten oder üblichen Vergütungssätzen abgerechnet werden.
- 6 Der Auftragnehmer unterstützt den Auftraggeber nach Möglichkeit und unter Berücksichtigung der Art der Verarbeitung bei der Beantwortung von Anträgen betroffener Personen nach Kapitel III DSGVO.
- 7 Der Auftragnehmer informiert den Auftraggeber unverzüglich über ihm bekannt gewordene Verletzungen des Schutzes personenbezogener Daten oder sonstige Vorfälle im Zusammenhang mit geheimnisschutzrelevanten Informationen.
- 8 Der Auftragnehmer führt ein angemessenes Berechtigungs- und Zugriffskonzept und beschränkt Zugriffe auf personenbezogene Daten und sonstige geschützte Informationen auf das für die Leistungserbringung erforderliche Maß.

6. Nachweis, Audits und Kontrollen

- 1 Der Auftragnehmer stellt dem Auftraggeber alle erforderlichen Informationen zum Nachweis der Einhaltung der in Art. 28 DSGVO niedergelegten Pflichten zur Verfügung.
- 2 Der Auftragnehmer kann Nachweise durch geeignete aktuelle Unterlagen, Selbstauskünfte, Zertifikate, Auditberichte, Vertragsunterlagen oder sonstige geeignete Dokumentationen erbringen, soweit dies im Einzelfall ausreichend ist. Solche Nachweise gehen einer Vor-Ort-Prüfung vor, soweit sie den Nachweiszweck angemessen erfüllen.
- 3 Der Auftraggeber ist berechtigt, nach angemessener Vorankündigung und unter Berücksichtigung berechtigter Geheimhaltungs-, Datenschutz- und Sicherheitsinteressen des Auftragnehmers Audits, Inspektionen oder Nachweisprüfungen selbst oder durch einen zur Verschwiegenheit verpflichteten Prüfer durchzuführen, sofern berechtigte datenschutzrechtliche Gründe dies erfordern und der Nachweis nicht bereits nach Ziffer 6.2 ausreichend erbracht wurde.
- 4 Audits haben grundsätzlich zu den üblichen Geschäftszeiten, mit angemessener Frist, ohne unverhältnismäßige Beeinträchtigung des Geschäftsbetriebs und ohne Gefährdung von Informationen anderer Kunden oder Betriebs- und Geschäftsgeheimnissen des Auftragnehmers zu erfolgen.
- 5 Soweit gesetzlich zulässig, trägt der Auftraggeber die durch individuelle Audits oder Sondernachweise verursachten Mehraufwände des Auftragnehmers, sofern diese nicht auf einem vom Auftragnehmer zu vertretenden erheblichen Datenschutzverstoß beruhen.

7. Unterauftragsverarbeiter

- 1 Der Auftraggeber erteilt dem Auftragnehmer die allgemeine Genehmigung, weitere Unterauftragsverarbeiter einzusetzen, soweit diese für die vertraglich geschuldeten Leistungen erforderlich sind.
- 2 Die bei Vertragsschluss eingesetzten Unterauftragsverarbeiter ergeben sich aus Anlage 3.
- 3 Der Auftragnehmer informiert den Auftraggeber in Textform über beabsichtigte Änderungen in Bezug auf die Hinzuziehung oder Ersetzung von Unterauftragsverarbeitern, sodass der Auftraggeber aus wichtigem datenschutzrechtlichem Grund innerhalb von 14 Tagen ab Zugang der Information widersprechen kann.
- 4 Mit jedem Unterauftragsverarbeiter wird eine Vereinbarung geschlossen, die diesem dieselben Datenschutzpflichten auferlegt, die in dieser Vereinbarung festgelegt sind, soweit dies nach Art. 28 DSGVO erforderlich ist.
- 5 Der Auftragnehmer bleibt gegenüber dem Auftraggeber für die Einhaltung der Pflichten des Unterauftragsverarbeiters verantwortlich.

8. Verarbeitung in Drittländern

- 1 Eine Verarbeitung personenbezogener Daten in einem Drittland oder ein Zugriff aus einem Drittland darf nur erfolgen, wenn die Voraussetzungen der Art. 44 ff. DSGVO erfüllt sind.
- 2 Soweit Unterauftragsverarbeiter oder technische Dienste in Drittländern eingesetzt werden, erfolgt dies ausschließlich auf Grundlage einer zulässigen Transfergrundlage, insbesondere eines Angemessenheitsbeschlusses oder geeigneter Garantien wie Standardvertragsklauseln.
- 3 Die derzeit bekannten Drittlandbezüge ergeben sich aus Anlage 3.
- 4 Soweit der Auftraggeber den Einsatz bestimmter Dienste, Integrationen, Provider oder technischer Architekturen vorgibt, freigibt oder wünscht, erfolgt deren Nutzung auf Grundlage dieser

projektbezogenen Entscheidung des Auftraggebers. Der Auftragnehmer weist auf erkennbare datenschutzrechtliche oder geheimnisschutzrelevante Risiken im Rahmen seiner technischen Kenntnis hin, übernimmt jedoch keine eigenständige rechtliche Gesamtbewertung des vom Auftraggeber gewünschten Setups.

9. Löschung und Rückgabe

- 1 Nach Abschluss der vertraglichen Leistungen oder jederzeit auf Weisung des Auftraggebers hat der Auftragnehmer personenbezogene Daten nach Wahl des Auftraggebers zurückzugeben oder datenschutzgerecht zu löschen, sofern keine gesetzliche Verpflichtung zur Aufbewahrung besteht.
- 2 Gesetzlich vorgeschriebene Aufbewahrungspflichten bleiben unberührt. In diesem Fall sind die Daten für andere Zwecke zu sperren.
- 3 Die Löschung erfolgt im Rahmen üblicher Betriebsabläufe und technischer Routinen. Hiervon ausgenommen bleiben Sicherungskopien und technisch unvermeidbare Restbestände, die nicht produktiv genutzt werden und spätestens im Rahmen regulärer Backup- und Löschzyklen entfernt oder überschrieben werden.
- 4 Der Auftragnehmer bestätigt dem Auftraggeber die Löschung oder Rückgabe auf Verlangen in Textform.

10. Besondere Vertraulichkeit und Geheimnisschutz

- 1 Diese Vereinbarung gilt für Projekte mit erhöhtem Schutzbedarf, insbesondere bei Auftraggebern, die besonderen gesetzlichen, berufsrechtlichen oder vertraglichen Geheimhaltungspflichten unterliegen oder bei denen besondere Kategorien personenbezogener Daten verarbeitet werden.
- 2 Als besonders geschützte Informationen gelten neben personenbezogenen Daten auch Mandats-, Patienten-, Klienten-, Beratungs- oder sonstige besonders vertrauliche Inhalte sowie Betriebs- und Geschäftsgeheimnisse des Auftraggebers oder seiner Kunden.
- 3 Soweit der Auftraggeber einem Berufsgeheimnis oder einer vergleichbaren besonderen gesetzlichen Verschwiegenheitspflicht unterliegt, werden die Parteien zusätzlich prüfen, ob ergänzende vertragliche Verpflichtungen zur Wahrung dieses Geheimnisschutzes erforderlich sind, insbesondere bei Tätigkeiten im Anwendungsbereich des § 203 StGB oder vergleichbarer Vorschriften.
- 4 Der Auftragnehmer wird in solchen Fällen nur solche Personen einsetzen, die in geeigneter Weise zur Vertraulichkeit und - soweit erforderlich - zur Wahrung des einschlägigen Berufs- oder Sondergeheimnisses verpflichtet wurden; soweit im konkreten Einsatz einschlägig, werden diese Personen zusätzlich ausdrücklich über die strafrechtlichen Konsequenzen einer unbefugten Offenlegung von Privatgeheimnissen gemäß § 203 StGB (Freiheitsstrafe oder Geldstrafe) belehrt.
- 5 Soweit eingesetzte Personen im Rahmen ihrer Tätigkeit Zugang zu geheimnisschutzrelevanten Informationen erhalten können, werden sie zusätzlich in geeigneter Weise über die besondere Sensibilität dieser Informationen und die möglichen rechtlichen Folgen einer unbefugten Offenlegung unterwiesen.
- 6 Der Auftraggeber bleibt verantwortlich für die Entscheidung, ob und in welchem Umfang in einem konkreten Projekt besondere Kategorien personenbezogener Daten oder berufsrechtlich geschützte Geheimnisse über bestimmte Formulare, Kommunikationswege, Integrationen oder Drittanbieter verarbeitet werden sollen.

11. Haftung

- 1 Die gesetzlichen Haftungsregelungen, insbesondere Art. 82 DSGVO, bleiben unberührt.
- 2 Im Übrigen gelten die Haftungsregelungen des Hauptvertrages nur insoweit, als keine zwingenden datenschutzrechtlichen Vorschriften entgegenstehen.

12. Schlussbestimmungen

- 1 Änderungen und Ergänzungen dieser Vereinbarung bedürfen mindestens der Textform, soweit gesetzlich nichts anderes vorgeschrieben ist.
- 2 Sollten einzelne Bestimmungen dieser Vereinbarung ganz oder teilweise unwirksam oder undurchführbar sein oder werden, bleibt die Wirksamkeit der übrigen Bestimmungen unberührt.
- 3 Im Zweifel geht diese Vereinbarung den allgemeinen Regelungen des Hauptvertrages vor, soweit die Verarbeitung personenbezogener Daten betroffen ist.
- 4 Soweit diese Vereinbarung Mitwirkungs-, Unterstützungs-, Prüf- oder Dokumentationspflichten des Auftragnehmers auslöst, die über die im Hauptvertrag geschuldete Leistung hinausgehen, erfolgt die Leistungserbringung - soweit gesetzlich zulässig - gegen gesonderte Vergütung nach Aufwand, sofern die Parteien nichts Abweichendes vereinbart haben.

Anlage 1: Beschreibung der Verarbeitung

1. Gegenstand der Verarbeitung

Technische Entwicklung, Wartung, Pflege, Support, Fehleranalyse, Deployment, Konfiguration und Administration im Zusammenhang mit der Website und den zugehörigen Diensten des Auftraggebers.

2. Zweck der Verarbeitung

Sicherstellung des technischen Betriebs, der Funktionsfähigkeit, Sicherheit, Aktualität und Weiterentwicklung der Webpräsenz und der daran angebotenen Systeme.

3. Verarbeitungsvorgänge

- 1 Zugriff auf Hosting-, DNS-, CDN-, Worker-, Pages-, CMS-, Mail- oder Repository-Umgebungen
- 1 technische Analyse von Logdateien und Fehlermeldungen
- 1 Deployment, Wartung, Versionsverwaltung und Wiederherstellung
- 1 Anpassung und Pflege von Formularen, Integrationen und Inhalten
- 1 Administration von Nutzer-, Rollen- und Zugriffsrechten

4. Datenarten

- 1 Kontaktdaten
- 1 Kommunikationsinhalte
- 1 Nutzungs- und Metadaten
- 1 IP-Adressen und Logdaten
- 1 Account- und Administrationsdaten

- 1 besondere Kategorien personenbezogener Daten
- 1 sonstige vertrauliche oder geheimnisschutzrelevante Informationen

5. Kategorien betroffener Personen

- 1 Websitebesucher
- 1 Interessenten, Kunden, Mandanten, Patienten, Klienten oder sonstige Anfragende
- 1 Beschäftigte und sonstige Nutzerkonten des Auftraggebers

Anlage 2: Technische und organisatorische Maßnahmen (TOM)

Die nachfolgenden Maßnahmen beschreiben das aktuelle Sicherheitsniveau des Auftragnehmers. Der Auftragnehmer ist berechtigt, Maßnahmen weiterzuentwickeln, sofern das Schutzniveau insgesamt nicht abgesenkt wird.

1. Vertraulichkeit

- 1 Zutrittskontrolle zu den Räumlichkeiten, in denen personenbezogene Daten oder sonstige geschützte Informationen verarbeitet werden, durch abschließbare Zugänge und Ausschluss unbefugter Dritter
- 1 Zugriff auf Endgeräte nur mittels starker Passwörter, PIN oder biometrischer Authentifizierung
- 1 Automatische Bildschirmsperre bei Inaktivität
- 1 Clear-Screen-Policy und Schutz vor Einsichtnahme durch Dritte im Arbeitsumfeld
- 1 Rollen- und berechtigungsbezogene Zugriffsbeschränkung auf Kundenkonten und Projektsysteme
- 1 Nutzung personalisierter Benutzerkonten
- 1 Einsatz von Mehr-Faktor-Authentifizierung, soweit vom eingesetzten Dienst unterstützt und für das betroffene System administrativ relevant
- 1 Sichere Verwaltung von Zugangsdaten und Tokens; keine unverschlüsselte dauerhafte Ablage in allgemein zugänglichen Dateien
- 1 Vertraulichkeitsverpflichtung der zur Verarbeitung berechtigten Personen
- 1 zusätzliche Unterweisung eingesetzter Personen über die besondere Sensibilität geheimnisschutzrelevanter Informationen bei entsprechenden Projekten

2. Integrität

- 1 Datenübertragung ausschließlich über verschlüsselte Verbindungen (TLS/HTTPS, SSH oder funktional gleichwertig)
- 1 Schutz vor unbefugter Veränderung durch Berechtigungs- und Rollenmanagement
- 1 Nachvollziehbarkeit wesentlicher Änderungen über Versionsverwaltung, Deployment-Historien oder Systemprotokolle, soweit technisch verfügbar
- 1 Trennung von Umgebungen und Projekten verschiedener Auftraggeber durch separate Repositories, Deployments, Konten oder logisch getrennte Bereiche

3. Verfügbarkeit und Belastbarkeit

- 1 Nutzung etablierter Cloud- und Hosting-Dienste mit georedundanter oder hochverfügbarer Infrastruktur, soweit Bestandteil des jeweiligen Kundensetups
- 1 Redundante Verfügbarkeit des Quellcodes über Versionsverwaltung
- 1 Geordnete Wiederherstellbarkeit über Repository- und Deployment-Stand
- 1 Regelmäßige Einspielung sicherheitsrelevanter Updates für lokal eingesetzte Systeme und Software in angemessenem zeitlichen Rahmen

4. Datenminimierung und Zugriffsbeschränkung

- 1 Zugriff auf personenbezogene Daten und sonstige geschützte Informationen nur, soweit dies für den jeweiligen Auftrag erforderlich ist
- 1 Verarbeitung in Test- und Supportfällen nach Möglichkeit mit minimierten Datensätzen
- 1 Keine über den Auftrag hinausgehende Nutzung, Auswertung oder Speicherung personenbezogener Daten

5. Incident-Management

- 1 Einsatz aktueller Betriebssysteme und Sicherheitsupdates auf den verwendeten Endgeräten
- 1 Einsatz marktüblicher Schutzmaßnahmen gegen Schadsoftware und unbefugte Zugriffe
- 1 Verfahren zur Erkennung, Bearbeitung und Meldung von Sicherheitsvorfällen in angemessenem Umfang
- 1 Unverzügliche Information des Auftraggebers bei bekannt gewordenen Datenschutzverletzungen oder sonstigen geheimnisschutzrelevanten Vorfällen mit Bezug zum Auftrag

6. Löschung und Aufbewahrung

- 1 Löschung oder Rückgabe personenbezogener Daten nach Weisung des Auftraggebers oder nach Vertragsende, soweit keine gesetzliche Aufbewahrungspflicht besteht
- 1 Beschränkung verbleibender Kopien auf technisch unvermeidbare oder rechtlich erforderliche Restbestände

7. Überprüfung und Evaluierung

- 1 Regelmäßige Überprüfung des Berechtigungsniveaus und der genutzten Accounts
- 1 Anlassbezogene Überprüfung der Sicherheitsmaßnahmen bei Änderungen der eingesetzten Systeme oder Dienste
- 1 Dokumentation wesentlicher sicherheitsrelevanter Konfigurationen und Verantwortlichkeiten in angemessenem Umfang

8. Erhöhter Schutzbedarf

Bei Projekten mit erhöhtem Schutzbedarf, insbesondere bei Gesundheitsdaten, Mandatsdaten, Berufsgeheimnissen oder vergleichbar sensiblen Informationen, werden die Maßnahmen risikoadäquat verschärft, insbesondere durch strengere Zugriffsbeschränkungen, konsequente Mehr-Faktor-Authentifizierung, reduzierte Administrationszugriffe, erhöhte organisatorische Vertraulichkeitsanforderungen und eine gesonderte Prüfung, ob einzelne eingesetzte Dienste, Kommunikationswege oder Übermittlungswege für diesen Schutzbedarf geeignet sind.

Anlage 3: Unterauftragsverarbeiter und Drittlandbezüge

Die folgende Liste gilt nur, soweit die jeweiligen Dienste im konkreten Kundenprojekt tatsächlich eingesetzt werden.

Zusätzliche oder geänderte Unterauftragsverarbeiter werden nach Maßgabe von Ziffer 7 dieser Vereinbarung mitgeteilt.

Unterschriften

Ort, Datum: ____

Für den Auftraggeber

Name: ____

Funktion: ____

Unterschrift: ____

Für den Auftragnehmer

Laurenz Gilbert

Gilbert Webdesign

Unterschrift: ____